

PayCarry Türkiye: A Huawei Cloud Security Architecture for Zero-CVE Ambition and Continuous PCI DSS Evidence

1. Executive Summary

PayCarry Türkiye needs to migrate a regulated fintech workload to Huawei Cloud TR-Istanbul without carrying today's cloud security debt into the next PCI DSS Level 1 renewal cycle.

My headline recommendation is to build a DevSecOps-led Huawei Cloud landing zone where vulnerabilities are blocked before release, production hosts are continuously monitored, and audit evidence is generated by default. The proposed architecture combines CodeArts, HSS Enterprise, WAF, KMS, SecMaster, CTS, LTS, Compliance Center, and OBS into one operating model. The goal is not to “buy compliance,” but to make secure delivery and evidence collection part of PayCarry’s normal engineering workflow.

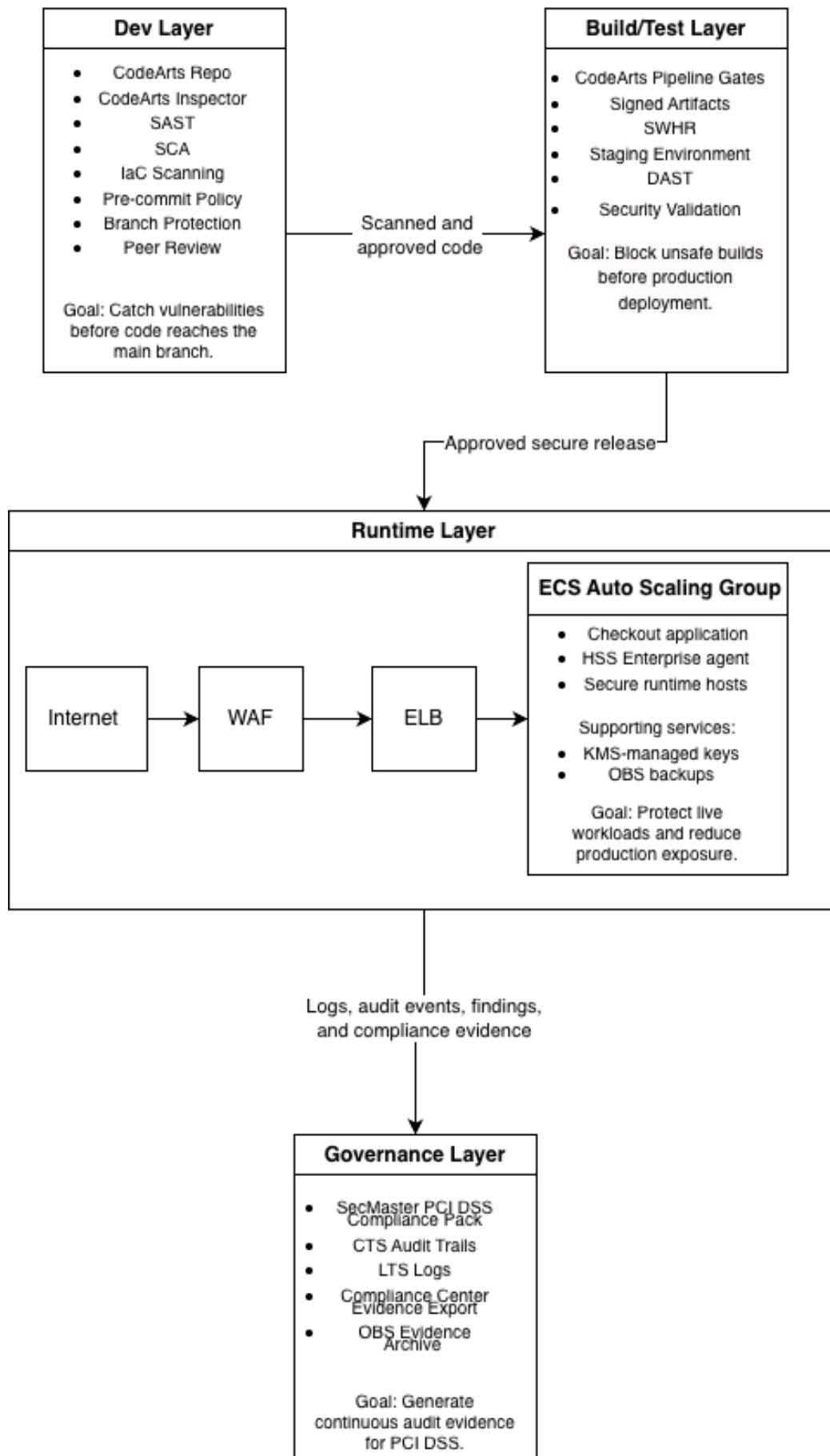
Ninety days after the project starts, “good” means PayCarry has one pilot payment workload running in TR-Istanbul, all code passing security gates, ECS hosts protected by HSS Enterprise, WAF and KMS controls enforced, SecMaster baseline checks active, and the first evidence package ready for internal audit review.

2. Architecture Overview

The proposed architecture is organized across four layers: Dev, Build/Test, Runtime, and Governance. The design assumes PayCarry will first migrate a pilot checkout or merchant transaction service, then expand the pattern to the rest of the cardholder data environment.

Figure 1. Proposed Huawei Cloud security architecture for PayCarry Türkiye

Huawei Cloud Security Architecture for PayCarry Türkiye



In the **Dev layer**, CodeArts Repo becomes the controlled source of truth for application and infrastructure code. Huawei Cloud CodeArts supports DevSecOps and CI/CD-oriented software delivery practices, while CodeArts Check provides cloud-based static code checking for code style, quality, and cybersecurity risks. Therefore, PayCarry should use repository rules, protected branches, pre-commit policies, and security scanning before code reaches the main branch.

The practical rule is simple: no code reaches the main branch unless it has passed automated security checks and human review. CodeArts Inspector is included in the target architecture for vulnerability-oriented inspection, while the wider CodeArts toolchain provides the delivery workflow. In PayCarry's operating model, the Dev layer should block exposed secrets, unsafe dependencies, insecure code patterns, and risky infrastructure-as-code changes before they become deployment artifacts.

In the **Build/Test layer**, CodeArts Pipeline enforces release gates. If a critical vulnerability, exposed secret, or high-risk IaC change is detected, the pipeline should fail. Approved builds are packaged as signed artifacts and stored in SWHR. Staging should run DAST against the application before production deployment, especially for login, payment, merchant onboarding, and public API endpoints. This is the layer where PayCarry turns security policy into an engineering rule: insecure builds cannot be promoted.

In the **Runtime layer**, production ECS hosts sit behind ELB and are protected by WAF at the edge. Huawei Cloud WAF examines website traffic and protects applications from common web attacks; Huawei also lists SQL injection, XSS, file inclusion, directory traversal, command/code injection, web shells, and third-party vulnerability exploits among the attack types WAF can detect and block.

ECS hosts run HSS Enterprise for host security, vulnerability management, baseline checks, process and asset visibility, and runtime protection. Huawei Cloud HSS describes asset management, baseline checks, and vulnerability management, including scanning for more than 200,000 vulnerabilities and fixing vulnerabilities in one click.

KMS-managed keys protect sensitive secrets and encryption keys through Huawei Cloud Data Encryption Workshop, which includes Key Management Service. OBS is used for backups and long-term evidence storage.

In the **Governance layer**, SecMaster provides security operations and baseline inspection. Huawei Cloud SecMaster baseline inspection can scan cloud service configurations, report risks by category, generate alerts, and provide hardening suggestions.

CTS records cloud resource operations for security analysis, compliance auditing, resource tracking, and fault locating, while LTS centralizes, queries, visualizes, and stores logs.

Compliance Center supports certification and evidence export. For PayCarry, this turns auditor requests into a repeatable monthly evidence workflow instead of a once-a-year manual scramble.

3. How We Get to “Zero CVEs in Production”

“Zero CVEs in production” should be treated as a target operating model, not a literal guarantee. PayCarry can get close by combining shift-left controls with runtime defense-in-depth.

The first control is early detection. A CVE found during development is dramatically cheaper to fix than the same CVE found after a production incident. In development, the fix may be a dependency upgrade, a configuration change, or a small code change. In production, the same issue may require incident response, emergency change approval, customer communication, regulator notification, forensic investigation, and downtime planning. This is why the Session 2 cost curve matters: the later a defect is found, the more expensive and disruptive it becomes. For PayCarry, every critical CVE should fail the pipeline before release.

The second control is dependency discipline. SCA should be mandatory for application libraries, container images, and open-source dependencies. IaC scanning should catch risky cloud changes before they are applied, such as public security group exposure, weak OBS bucket policies, or missing encryption. These checks are especially important during migration because cloud infrastructure often changes quickly and mistakes can be repeated across environments.

The third control is runtime safety. HSS Enterprise provides vulnerability management for ECS workloads and can help identify vulnerabilities in operating systems and software. Huawei Cloud HSS states that it can scan for more than 200,000 vulnerabilities and fix them in one click.

However, PayCarry should not blindly patch production servers. The safe workflow is: classify the vulnerability, check business impact, take an ECS snapshot or confirm rollback coverage, apply the fix first to staging, and then patch production in a controlled maintenance window. The “snapshot-before-fix” approach gives the team a rollback path if a patch breaks a payment dependency.

The honest caveat is that no cloud architecture can promise permanent zero CVEs. Emergency vulnerabilities such as Log4Shell-class events can appear suddenly, before scanners, vendors, and internal teams have fully adapted. This means PayCarry still needs an emergency response process: rapid exposure assessment, temporary WAF rules, affected asset inventory, compensating controls, emergency patching, and executive notification.

The success metric is therefore not “we will never see a CVE.” The success metric is this: critical CVEs do not reach production through normal releases, runtime CVEs are detected quickly, emergency vulnerabilities are triaged within hours, and remediation evidence is captured automatically.

4. How We Get Continuous PCI DSS Evidence

PCI DSS evidence should not be collected once a year. For PayCarry, it should be generated continuously by the platform. PCI DSS defines technical and operational requirements to protect environments where payment account data is stored, processed, or transmitted.

The first step is subscribing to the PCI DSS compliance pack in SecMaster and enabling baseline inspection for the TR-Istanbul environment. Huawei Cloud states that its PCI DSS certification covers more than 200 Huawei Cloud services, including WAF, DEW, and DBSS.

SecMaster baseline inspection can then scan cloud configurations, report risks by category, generate alerts, and provide hardening suggestions.

This gives PayCarry a living compliance dashboard rather than a spreadsheet maintained only before the audit. Some checks can be automated, such as whether logging is enabled, whether risky configurations exist, or whether security services are active. Other checks remain manual, such as policy approval, staff training, incident response exercises, and evidence that procedures are actually followed.

A concrete example is **PCI DSS Requirement 1**, which focuses on network security controls. In the proposed architecture, WAF protects public web applications, ELB controls inbound service exposure, VPC security groups restrict network paths, and perimeter access rules limit unwanted traffic. CTS records administrative changes to network resources, while LTS stores access and security logs for review. SecMaster baseline checks can identify risky network configurations and generate findings for remediation. This creates a direct chain from PCI expectation to Huawei Cloud control to audit evidence.

The second evidence stream is identity and operations evidence. CTS records cloud resource operations and supports security analysis, compliance auditing, resource tracking, and fault locating.

For a PCI auditor, this matters because PayCarry must show who changed what, when, from where, and whether the change was authorized. CTS traces should be exported or retained for long-term evidence. LTS should collect application logs, WAF logs, ELB logs, and security logs so the team can search for incidents and produce reports without rebuilding history. Huawei Cloud LTS supports log centralization, query, visualization, storage, structured query, and permanent storage in OBS.

Compliance Center then becomes the evidence packaging layer. Instead of asking engineers to manually collect screenshots, policies, logs, and certificates before the audit, PayCarry can maintain a monthly evidence export routine. Compliance Center materials, SecMaster findings, CTS traces, LTS reports, HSS vulnerability reports, and change approvals can be stored in an OBS evidence bucket with strict IAM access and KMS encryption.

The honest caveat is that PCI DSS is not only a cloud configuration standard. No cloud provider can automatically prove that PayCarry trains staff, approves policies, performs risk assessments, manages vendors, or follows incident response procedures. Huawei Cloud can make technical evidence continuous, but PayCarry must still own governance, accountability, and business-process evidence.

5. Risk Register

Risk	Probability	Impact	Mitigation
Smaller Huawei Cloud talent pool in Türkiye compared with AWS or Azure	Medium	Medium	Train the platform team early, create internal runbooks, and use Huawei Cloud support during migration.
Regional service parity gaps in TR-Istanbul	Medium	High	Validate every required SecMaster, HSS, CodeArts, WAF, KMS, and Compliance Center feature before final migration.
PCI renewal timeline conflicts with migration	Medium	High	Start with a pilot workload, preserve existing audit evidence, and avoid moving the full cardholder data environment too late.
Partner or procurement concerns about cloud provider risk	Low/Medium	Medium	Prepare a due diligence pack using Huawei Cloud Trust Center, Compliance Center, shared responsibility documents, and architecture evidence.
Lock-in to Huawei-specific DevSecOps tooling	Medium	Medium	Keep policies as code, export scan results, use standard artifact formats, and maintain an exit plan for repositories and pipelines.

The largest risk is timing. PayCarry has 18 months until PCI DSS Level 1 renewal, which sounds comfortable, but cloud migration, application refactoring, evidence generation, and audit remediation can easily consume that time. The migration must therefore be staged, not treated as a single cutover.

6. Next 90 Days

The first 90 days should prove the model with one representative workload rather than attempting a full migration.

Week 1–2: Foundation

- Create Huawei Cloud accounts, projects, and IAM groups.
- Enforce MFA and least privilege.

- Build the VPC, subnet, security group, KMS, OBS, CTS, and LTS landing zone.
- Define the evidence bucket structure and retention rules.

Week 3–6: Pilot Runtime

- Migrate one pilot workload to TR-Istanbul.
- Place ECS behind ELB and WAF.
- Enable HSS Enterprise on all pilot ECS hosts.
- Turn on SecMaster baseline inspection.
- Send application, WAF, ELB, and host logs into LTS.

Week 7–10: DevSecOps Pipeline

- Move the pilot repository into CodeArts Repo.
- Add CodeArts Inspector and CodeArts Check gates for SAST, SCA, and IaC-oriented reviews.
- Block critical CVEs from production deployment.
- Store signed build artifacts in SWHR.
- Run DAST against staging before production release.

Week 11–13: Compliance Evidence

- Subscribe to the PCI DSS compliance pack.
- Run the first baseline scan.
- Remediate high-risk gaps.
- Export CTS, LTS, HSS, SecMaster, and Compliance Center evidence.
- Conduct a mock audit with the CTO, security lead, and compliance owner.

At the end of 90 days, PayCarry should not claim final PCI readiness. It should claim something more credible: the migration control pattern works, evidence is being produced continuously, and the remaining gaps are visible, assigned, and scheduled.

Sources

1. Huawei Cloud CodeArts Product Page — <https://www.huaweicloud.com/intl/en-us/product/devcloud.html>
2. Huawei Cloud CodeArts Check Documentation — <https://support.huawei.com/enterprise/en/doc/EDOC1100372275/828e00d3/what-is-codearts-check>
3. Huawei Cloud CodeArts Inspector Documentation — <https://support.huawei.cn/enterprise/en/doc/EDOC1100521524/6b02a07b/what-is-codearts-inspector>
4. Huawei Cloud Host Security Service Product Page — <https://www.huaweicloud.com/intl/en-us/product/hss.html>

5. Huawei Cloud SecMaster Baseline Inspection Documentation —
https://support.huaweicloud.com/intl/en-us/usermanual-secmaster/secmaster_02_0028.html
6. Huawei Cloud Cloud Trace Service Product Page —
<https://www.huaweicloud.com/intl/en-us/product/cts.html>
7. Huawei Cloud Log Tank Service Product Page —
<https://www.huaweicloud.com/intl/en-us/product/lts.html>
8. Huawei Cloud Web Application Firewall Product Page —
<https://www.huaweicloud.com/intl/en-us/product/waf.html>
9. Huawei Cloud Data Encryption Workshop Product Page —
<https://www.huaweicloud.com/intl/en-us/product/dew.html>
10. Huawei Cloud PCI DSS Compliance Center —
<https://www.huaweicloud.com/intl/en-us/securecenter/compliance/compliance-center/pci-dss.html>
11. PCI Security Standards Council PCI DSS Standards Page —
<https://www.pcisecuritystandards.org/standards/>